WeConnect 2.0 — Remediation Plan

What to fix, in what order, and the structural change behind each

Prepared for Lighthouse Communities Foundation
Date 20 October 2026

This plan groups the 87 defects into seven workstreams, ordered so the root causes are fixed first. Each workstream names the one structural change that closes most of its findings, rather than listing 87 separate patches. Fixing by workstream prevents the pattern we have already seen, where a point fix to one endpoint leaves the same flaw in the forty beside it.

1. Order of work

#	Workstream	Findings	Contains
A	Authorisation model — the root cause of all three S1 breaches	22	3 S1, 12 S2
B	Secrets and sensitive-data hygiene	7	4 S2
C	API robustness and a single response contract	18	9 S2
F	Platform configuration, infrastructure and scale	13	7 S2
D	Front-end resilience and user experience	14	4 S2
E	Accessibility	3	1 S2
G	Build, ownership and reproducibility	10	3 S2

A, B and F carry the security weight and should come first. C and D remove the day-to-day crashes and broken screens. E and G are lower urgency but cheap, and G protects everything else by making the platform rebuildable.

2. Workstream A — Authorisation model

The structural change. Give every doctype a real role-permission entry and stop bypassing permissions in application code. Today the design has no model: every staff account is forced to hold `System Manager`, and the code then reads that role as "no restriction" while saving with `ignore_permissions`. The complete role matrix is in the separate *Permission Model Proposal*; apply it as versioned fixtures, then remove the per-call bypasses so that `User Permission` centre-scoping is actually consulted.

Progress noted, and a risk. You have removed `System Manager` from the live accounts and added a centre-scope layer to the invoice API — both correct moves, and the invoice breach (WC-095) now appears closed because the accounts it would run as are no longer exempt. But `ignore_permissions` has not fallen (322 sites, slightly up), so authorisation is now enforced inconsistently, endpoint by endpoint, rather than by one model. Removing the role before the DocPerm matrix is fully in place is the sequence the proposal warned against: accounts keep working only because the code still bypasses permissions.

Closes: WC-073, WC-079, WC-105, WC-084, WC-048, WC-035, WC-085, WC-095, WC-069, WC-091, WC-122, WC-123, WC-114, WC-080, WC-109, WC-115, WC-065, WC-024, WC-071, WC-092, WC-078, WC-077.

3. Workstream B — Secrets and sensitive-data hygiene

The structural change. No secret in a repository, no secret in a log, no long-lived credential in the browser. Move all keys and `.env` values to deployment-time configuration; rotate the two Google keys and any API secret that has been committed, since the repository was public; purge them from git history. Stop writing the reset OTP and email to the browser console. Move the API token out of `localStorage` into an `httpOnly` cookie, and shorten the seven-day session.

Partly done. The OTP is now drawn with a cryptographic generator (WC-131) — good — but it is still four digits, and the reset flow still logs it to the console (WC-128), so this workstream is not yet closed.

Closes: WC-004, WC-129, WC-013, WC-128, WC-131, WC-116, WC-003.

4. Workstream C — API robustness and a single response contract

The structural change. One response envelope, one error convention, validation at the boundary. The platform currently ships two different success shapes and returns HTTP 200 on failure, 500 on a missing argument, and a raw Python traceback in the error body. Standardise on one envelope; validate inputs before use so a missing field is a 400, not a 500; strip tracebacks from responses; add state-transition control and self-consistent field validation so records cannot hold contradictory values; make financial and state-changing calls idempotent.

Closes: WC-023, WC-074, WC-076, WC-089, WC-096, WC-101, WC-104, WC-018, WC-002, WC-019, WC-068, WC-088, WC-103, WC-126, WC-125, WC-099, WC-038, WC-120.

5. Workstream F — Platform configuration, infrastructure and scale

The structural change. Harden the edge and fix the concurrency ceiling. Serve security headers, lock CORS to known origins instead of reflecting any, add rate limiting, and raise the dependency versions that carry known advisories. Separately, find and remove the root cause of the 500s under three-to-five concurrent sessions — a worker, connection-pool or locking limit — because it caps how many centre staff can use the platform at once.

Closes: WC-112, WC-121, WC-118, WC-020, WC-047, WC-011, WC-031, WC-014, WC-030, WC-117, WC-127, WC-106, WC-110. (WC-011, the disabled auth guard, is already fixed.)

6. Workstream D — Front-end resilience and user experience

The structural change. A screen should degrade, not disappear. Add a React error boundary to every application, and make screens null-safe so a route entered directly by URL — refreshed, bookmarked, or reached with no assigned data — renders an empty state instead of a blank crash. This closes the blank-route family at its root rather than one route at a time.

Partly done. WC-130, the stored-XSS sink, is fixed. Error boundaries now exist in two of nine apps; the other seven still blank out on any component fault.

Closes: WC-016, WC-043, WC-136, WC-133, WC-017, WC-010, WC-009, WC-007, WC-008, WC-032, WC-041, WC-005, WC-006, WC-130.

7. Workstream E — Accessibility

The structural change. Fix the shared navigation components once, and the critical violations clear across every screen that uses them; add alt text and correct the low-contrast colours; add the `jsx-a11y` lint rule so regressions are caught in review.

Closes: WC-027, WC-028, WC-134.

8. Workstream G — Build, ownership and reproducibility

The structural change. The platform must be rebuildable from the repositories alone. Bring the runtime configuration and permission fixtures into version control, resolve ownership of the `fintoo` application that is installed but in no repository, remove the orphaned and duplicated doctype definitions, and ship the Approval Categories the code references by name. Until this is done, a clean install does not reproduce the

running platform.

Closes: WC-058, WC-087, WC-055, WC-059, WC-062, WC-063, WC-072, WC-108, WC-111, WC-097.

9. How to verify fixes

Every finding carries a re-check: the security and configuration items have a runnable command (`node verify/run.mjs`), the code items a named file and line, and the write-side items a reproduction that runs on the isolated stack. Re-run these after each workstream rather than at the end, so a fix is confirmed closed and a regression is caught in the workstream that caused it.